

Active Directory Book: Author Notes

Target Audience

- Federal Civilian Agencies
- Department of Defense (DoD) Organizations
- Combatant Commands
- Service Components
- Defense Agencies
- Intelligence Community Organizations
- Defense Contractors (DIB)
- National Security Systems (NSS) Environments

Because Military Services and Branches follow same AD compliance measures as civilian bodies, I will systematically replace many occurrences of just “Federal Active Directory” now with “Federal and Military Active Directory,” or “Federal and Department of Defense (DoD) Identity Infrastructures” depending on context. The reason behind this thought is simple: A GS-13 ISSO supporting DHS (Department of Homeland Security) and a DoD Cybersecurity Engineer supporting an Air Force enclave have far more in common than does with a Fortune 500 AD administrator. This distinction shall be reflected throughout the entirety of the book.

CHAPTER 1 – THE CASE FOR FEDERAL AND MILITARY ACTIVE DIRECTORY FICAM DOMAINS AND NETWORKS

This chapter answers: Why Does This Book Exist?

This chapter establishes the need for a specialized approach to securing, assessing, defending, and hunting threats within federal Active Directory environments. It introduces the concepts of Federal Identity, Credential, and Access Management (FICAM), explains why Active Directory remains a critical component of federal identity infrastructure, and demonstrates how Command mission assurance, compliance requirements, and advanced threat actors have transformed identity systems into high-value operational targets.

CHAPTER 2. FEDERAL CYBERSECURITY GOVERNANCE AND REGULATORY AUTHORITIES

CHAPTER PURPOSE

This chapter answers: Who governs federal cybersecurity, federal identity, and Active Directory security decisions?

Most commercial Active Directory books completely skip this topic. Yet in a federal environment, many AD engineering decisions originate from requirements established by authorities that most administrators rarely think about or even know about, for that matter.

This chapter will explain not only who these organizations are, but also how their guidance ultimately influences domain controller configurations, authentication policies, PKI deployments, privileged access and management strategies, RMF and security control deployments and enforcements, STIG implementations, and FICAM architecture.

CHAPTER 3. THE RISK MANAGEMENT FRAMEWORK (RMF) AND IDENTITY-CENTRIC SECURITY ENGINEERING

CHAPTER PURPOSE

This chapter answers: How are the rules operationalized throughout the RMF lifecycle process?

After building Chapters 1 and 2, I now think Chapter 3 should become one of the most important chapters in the entire book – not merely an RMF overview.

Most cybersecurity books treat RMF as a compliance topic. Federal identity professionals know that's not reality. First and foremost, RMF drives:

- Active Directory architecture decisions
- Privileged access decisions
- Authentication requirements
- PKI deployments and enforcements
- CAC/PIV implementations
- STIG deployments and enforcements
- Assessment activities
- POA&M development
- Continuous monitoring

In a federal environment, RMF is the operational framework that ultimately determines what an AD engineer, ISSO, ISSM, assessor, or AO is allowed to do.

So, instead of:

Chapter 3. Federal Risk Management Framework (RMF)

I am going to elevate it to:

Chapter 3. Federal Risk Management Framework (RMF) for Federal and Military Environments

I also think this chapter should answer a fundamental question that almost no RMF books on the shelves answer today:

What does RMF actually look like from an Active Directory engineer's perspective?

For example, most RMF books explain broadly:

- Categorize
- Select
- Implement
- Assess
- Authorize
- Monitor

However, they rarely explain:

- Implement
 - o What AD configurations are being implemented?
- Assess
 - o What AD evidence and artifacts are assessors actually reviewing?
- Authorize
 - o What AD risks concern an Authorizing Official (AO)?
- Monitor
 - o What AD events should continuously be monitored?

This should become the differentiator in Chapter 3.

I will build Chapter 3 around three parallel viewpoints:

1. RMF Perspective – what the framework says
2. Active Directory Engineer Perspective – what must actually be configured
3. Assessor Perspective – what evidence and artifacts must be produced

I am also going to introduce concepts that most RMF text omits:

- Identity as a Security Control Provider
- AD as a common control provider

- Enterprise services
- Shared services
- Control inheritance
- Identity Risk
- Authentication risk
- Authorization risk
- Federation risk
- Credential risk
- Privileged access risk
- Mission Risk

And should aim to address questions, such as:

- What happens when AD/AD DS fails?
- What happens when AD DS is compromised?
- What happens when PKI/AD CS is compromised?
- What happens when federation/AD FS is compromised?

Chapter 3 will be the foundational chapter for every other chapter that follows:

- Chapter 4 (STIG/SRG)
- Chapter 5 (CCRI/CORA)
- Chapter 6 (VMS/eMASS)

Because those three chapters are essentially RMF implementation chapters.

The flow now becomes:

Chapter 1. Why Federal Identity Matters

↓

Chapter 2. Who Governs Federal Cybersecurity

↓

Chapter 3. How Federal Cybersecurity Risk Is Managed Through RMF

↓

Chapter 4. How RMF Becomes Technical Controls Through STIGs and SRGs

↓

Chapter 5. How Commands and Agencies Are Evaluated Through CCRI/CORA

↓

This chapter introduces the Risk Management Framework (RMF) as the foundational cybersecurity governance process used throughout federal civilian agencies and military branches, Department of Defense organizations, defense contractors, and National Security Systems (NSS). Particular emphasis is placed on understanding how the RMF strongly influences the design, implementation, assessment, authorization, operation, and continuous monitoring of Active Directory, FICAM PKI, federation, and identity-centric security architectures.

Readers will learn how federal and military-based identity systems function as common control providers within RMF-authorized environments and how identity-related risks directly influence Command and Combatant mission assurance, operational readiness, and authorization decision-making.

CHAPTER 4. SECURITY TECHNICAL IMPLEMENTATION GUIDES (STIGs), SECURITY REQUIREMENTS GUIDES (SRGs), AND ACTIVE DIRECTORY COMPLIANCE ENGINEERING FOR FEDERAL AND MILITARY ENVIRONMENTS

CHAPTER PURPOSE

This chapter answers: How do federal and military cybersecurity requirements become technical security controls within Active Directory and identity infrastructure?

In Chapter 3, readers learned how the Risk Management Framework (RMF) establishes the governance process for identifying, assessing, authorizing, and monitoring cybersecurity risk; however, RMF itself does not prescribe the exact technical remediation and secure configurations that administrators, engineers, and security practitioners must implement within production AD environments.

The practical implementation of RMF security controls occurs through a series of technical guidance documents, security baselines, implementation standards, and assessment criteria. Within Department of Defense (DoD), National Security Systems (NSS), Combatant Commands, Service Components, Defense Agencies, and Federal Civilian Agencies and Military Branches, these requirements are most operationalized through Security Technical Implementation Guides (STIGs) and Security Requirements Guides (SRGs).

For Active Directory security engineers, identity architects, Information Systems Security Engineers (ISSEs), Information Systems Security Officers (ISSOs), Information Systems Security Managers (ISSMs), security and audit assessors, and Authorizing Officials (AOs), STIGs and SRGs serve as the technical bridge between governance requirements and operational security implementation.

Chapter 4 demonstrates exactly how RMF security controls are translated into real-world Active Directory secure and hardened configurations including (but not limited to):

- Authentication controls
- Authorization controls
- Domain controller security and hardened configurations
- Privileged access restrictions
- Public Key Infrastructure (PKI) implementations
- Active Directory Certificate Services (AD CS) security controls
- Active Directory Federation Services (AD FS) security controls
- Logging and auditing requirements
- Configuration management requirements
- Continuous monitoring requirements

Most cybersecurity texts discuss STIGs only from a compliance perspective. Federal and Military cybersecurity professionals already understand that STIGs and SRGs influence nearly every aspect of enterprise identity security architecture. Domain controller configurations, administrative workstations (e.g., PAWs and SAWs), privileged access management (PAM) information systems, Certificate Authorities (CAs), federation services, auditing infrastructure, and endpoint configurations are all directly influenced by STIG and SRG requirements.

This chapter, therefore, examines STIGs and SRGs through three parallel viewpoints:

1. Governance Perspective

How STIGs and SRGs support the RMF, NIST SP 800-53, FISMA, DoD Cybersecurity Policy, and Command and Combatant Mission Assurance objectives.

2. Active Directory Security Engineer Perspective

How security requirements are translated into Group Policy Objects (GPOs), security baselines, domain configurations, authentication policies, auditing and auditable controls, and identity infrastructure hardening measures.

3. Assessor Perspective

How STIG and SRG compliance is validated, what evidence and artifacts are collected, how findings are documented and tracked until final remediation and closure, and how deficiencies influence authorization decisions.

Readers will also learn why compliance does not automatically equal absolute

security, how misconfigured identity infrastructure continues to pass assessments, and why effective enterprise defenders must understand both technical implementation, implications, and operational risk factors.

Because STIG and SRG findings frequently become POA&M (Plan of Action and Milestone) items, CCRI findings, CORA findings, Inspector General (IG) observations, and RMF assessment deficiencies, this chapter serves as the foundation for the chapters to follow:

- Chapter 5 (CCRI and CORA Readiness Assessment)
- Chapter 6 (eMASS, POA&M Management, and Compliance Documentation)
- Chapter 7 (Continuous Monitoring, Vulnerability and Patch Management)

By the conclusion of this chapter, readers will have a thorough understanding of how federal and military identity security requirements move from policy, to RMF controls, to STIG requirements, to production Active Directory environments.

Chapter 4 mirrors the depth, granularity, and instructional flow of Chapter 3 and creates a direct bridge into Chapter 5 (CCRI/CORA), where many of these same STIG findings become inspection findings.

Chapter 6. Federal and Military Cybersecurity Assessments Versus Commercial and Public-Sector Cybersecurity Assessments

This chapter answers a question many readers will have from the beginning: “I’ve worked in commercial cybersecurity for years. Why is Federal and Military cybersecurity so different?”

If Chapter 1 establishes why the book exists, then Chapter 6 establishes why the remainder of the book cannot be approached with a purely commercial mindset.

CHAPTER PURPOSE

This chapter examines the fundamental differences between cybersecurity assessment methodologies used within federal civilian agencies, military organizations, defense contractors, and National Security Systems (NSS) versus those commonly employed within commercial enterprises and non-federal public-sector organizations. Readers will explore differences in governance, risk management, operational objectives, compliance requirements, assessment scopes, threat models, reporting and documentation structures, and Command and Combatant mission assurance considerations.

Chapter 7 – Network Architecture, TCP/IP, and Enterprise Communications Foundations for Identity Infrastructure

Chapter Purpose

This chapter establishes the networking foundations that are necessary for understanding how Active Directory, Kerberos, LDAP, DNS, PKI, federation services, and identity-centric security architecture operate within federal and military enterprise environments. Readers will learn how identity services depend upon network communications, routing, name resolution, segmentation, trust boundaries, and enterprise connectivity. Emphasis is placed on understanding networking from the perspective of authentication, authorization, directory services, and identity infrastructure security.

Chapter 28 (Reconnaissance)

Chapter 30 (BloodHound)

Chapter 33 (Password Attacks)

Chapter 35 (Pass-the-Hash)

Chapter 36 (Kerberoasting)

Chapter 41 (DCSync)

Chapter 45 (Persistence)